

Security Lab GRC Documentation

AICPA, SOC 2 Trust Services Criteria (CC1-CC9)



AICPA[®]



HOMELAB

DEVSECOPS PLATFORM

Created By: Paul Leone

April 4, 2026



Table of Contents

SOC 2 Trust Services Criteria (Common Criteria CC1-CC9)	2
Overview	2
Overall Assessment	2
Common Criteria Implementation Detail	3
CC1: Control Environment	3
CC2: Communication and Information	4
CC3: Risk Assessment	5
CC4: Monitoring of Controls	6
CC5: Control Activities	6
CC6: Logical and Physical Access Controls	7
CC7: System Operations	9
CC8: Change Management	11
CC9: Risk Mitigation	12
Coverage Summary	12
Status by Category	12
Key Strengths	13
Gaps and Observations	13
Version History	13

SOC 2 Trust Services Criteria (Common Criteria CC1-CC9)

Document Control:

Version:	1.0
Last Updated:	April 2026
Owner:	Paul Leone
Prior Version:	N/A
Framework:	AICPA Trust Services Criteria (TSC) Security / Common Criteria
Scope:	On-premises homelab + hybrid cloud (AWS, Azure, GCP, 6 nodes via Tailscale)



Overview

SOC 2 is an attestation framework developed by the AICPA that evaluates whether a service organization's controls meet the Trust Services Criteria (TSC). The Security criteria (Common Criteria CC1-CC9) are required for every SOC 2 engagement; Availability, Confidentiality, Processing Integrity, and Privacy are optional based on the services provided. This document maps the Security Common Criteria to lab controls, demonstrating familiarity with the SOC 2 control framework from an audit-readiness and implementation perspective.

The Common Criteria are organized across nine categories aligned to the COSO internal control framework: Control Environment (CC1), Communication and Information (CC2), Risk Assessment (CC3), Monitoring of Controls (CC4), Control Activities (CC5), Logical and Physical Access Controls (CC6), System Operations (CC7), Change Management (CC8), and Risk Mitigation (CC9). Each criterion includes one or more Points of Focus that describe how effective implementation is demonstrated.

Important context: SOC 2 is designed for service organizations handling customer data. This lab is a personal research environment with no customer data in scope. The mapping below demonstrates control design and implementation capability aligned to SOC 2 criteria; it is not equivalent to a formal Type I or Type II attestation.

Overall Assessment

Category	Criteria	Assessment
CC1: Control Environment	CC1.1- CC1.5	Partial
CC2: Communication and Information	CC2.1- CC2.3	Implemented
CC3: Risk Assessment	CC3.1- CC3.4	Implemented
CC4: Monitoring of Controls	CC4.1- CC4.2	Implemented
CC5: Control Activities	CC5.1- CC5.3	Implemented

CC6: Logical and Physical Access	CC6.1-CC6.8	Implemented
CC7: System Operations	CC7.1-CC7.5	Implemented
CC8: Change Management	CC8.1	Implemented
CC9: Risk Mitigation	CC9.1-CC9.2	Partial
Overall	35 criteria	Strong

Common Criteria Implementation Detail

CC1: Control Environment

CC1.1	COSO Principle 1: Demonstrates Commitment to Integrity and Ethical Values	Lab mission statement defines security-first architecture principles with documented ethical guidelines for security research. Security policy documentation (version-controlled in Git) establishes acceptable use standards, responsible disclosure principles, and research boundaries. All security testing confined to owned infrastructure with no unauthorized scanning of external systems. Offensive tooling (Kali Linux, Parrot OS) isolated to dedicated test VMs on separate VLANs with explicit traffic controls preventing egress to unauthorized targets.	Partial
CC1.2	COSO Principle 2: Exercises Oversight Responsibility	Security architecture documented and reviewed quarterly against NIST CSF, CIS Controls, and ISO 27001 baselines. GRC documentation suite (seven frameworks) provides structured oversight of control effectiveness. Vulnerability remediation SLAs defined (Critical less than 72h, High less than 7 days) with tracking via TheHive. Grafana dashboards (20+) provide continuous posture visibility. Quarterly access reviews validate RBAC group assignments and permission grants in Authentik.	Partial
CC1.3	COSO Principle 3: Establishes Structure, Authority, and Responsibility	Role-based access control (RBAC) via Authentik groups with documented permission assignments per role (Admin, SOC Analyst, Read-Only). Separate privileged accounts for administrative operations; no dual-use accounts. Least-privilege enforced via Authentik OAuth2 scopes, SSH sudo policies, and firewall ACLs. Infrastructure responsibilities documented in Ansible inventory and IaC configurations: each service has a defined owner, configuration baseline, and update schedule.	Implemented
CC1.4	COSO Principle 4: Demonstrates Commitment to Competence	Lab environment purpose-built to develop and demonstrate competency across security domains: network defense (pfSense/OPNsense/Palo Alto PA-VM), endpoint detection (Wazuh EDR), identity	Implemented

		management (Authentik, Active Directory, Step-CA PKI), threat intelligence (MISP, CrowdSec), SIEM/SOAR (Splunk, Elastic, Shuffle, TheHive), vulnerability management (OpenVAS, Nessus), and infrastructure automation (Terraform, Ansible). Continuous learning validated through GRC documentation aligned to seven industry frameworks (NIST CSF 2.0, CIS Controls v8.1, ISO 27001:2022, NIST SP 800-53 Rev 5, MITRE ATT&CK v18.1, CISA ZTMM v2.0, NIST SP 800-207).	
CC1.5	COSO Principle 5: Enforces Accountability	All administrative actions logged to dual SIEM (Splunk + Elastic) with 90-day hot retention and 1-year cold storage. Immutable audit trails (Splunk read-only indexes, Elastic immutable streams) prevent log tampering. Sudo usage logged to SIEM; privileged SSH sessions tracked per session. Git commit history provides immutable record of all IaC and configuration changes with author attribution. Wazuh Active Response logs all automated containment actions (firewall-drop, host-deny, account-disable) with timestamps and triggering rule.	Implemented

CC2: Communication and Information

CC2.1	COSO Principle 13: Uses Relevant Information	Security posture data collected from multiple sources and acted upon: vulnerability scan results (OpenVAS weekly, Nessus monthly) feed patch prioritization workflows. SIEM correlation rules (100+ active) generate actionable alerts from raw log data. MISP threat intelligence correlates IOCs across network logs, endpoint telemetry, and application data. CIS Benchmark compliance scores (92-98% across 30+ hosts) drive remediation backlog. PatchMon tracks 5,000+ packages with CVE correlation to NVD, surfacing security-relevant update information daily.	Implemented
CC2.2	COSO Principle 14: Communicates Internally	Multi-channel alerting architecture ensures security events reach all relevant parties: Discord private server (dedicated channels per tool: #wazuh, #suricata, #pfsense, #grafana, #openvas, #prometheus); SMTP relay via Gmail for formal notifications; PagerDuty for critical escalations; TheHive case management for structured incident communication. Grafana dashboards provide continuous security posture visibility. Shuffle SOAR workflows automate notification routing based on alert severity and type.	Implemented
CC2.3	COSO Principle 15:	Responsible disclosure practices in place for any vulnerabilities identified during security research.	Implemented

Communicates Externally	MISP threat intelligence platform supports bi-directional IOC sharing with external threat intelligence communities (MISP feeds, Cortex enrichment). Cloudflare email routing configured for external alert delivery. No customer-facing services in scope; external communication focus is security community participation and threat intelligence sharing.
-------------------------	---

CC3: Risk Assessment

CC3.1	COSO Principle 6: Specifies Suitable Objectives	Security objectives defined and documented in lab mission statement: threat detection and response (SIEM/XDR, sub-30-minute MTTR), defense-in-depth architecture, continuous monitoring (100% security event coverage), and vulnerability management (Critical less than 72h MTTR). Service criticality tiers defined (Tier 1: SIEM/EDR, Tier 2: Firewalls/DNS/Identity, Tier 3: Supporting services) to prioritize protection and recovery efforts. Compliance objectives documented per framework with measurable targets (93% IG1 CIS Controls, Advanced CISA ZTMM, 92-98% CIS Benchmark).	Implemented
CC3.2	COSO Principle 7: Identifies and Analyzes Risk	Risk identification via continuous vulnerability scanning: weekly OpenVAS network scans (52/year), monthly Nessus authenticated scans (12/year), daily PatchMon CVE correlation for 5,000+ packages across 30+ hosts. CVSS base, temporal, and environmental scoring with asset criticality weighting. MISP threat intelligence feeds surface emerging risks. CrowdSec community signals identify active threat campaigns. Risk-based remediation prioritization with documented SLAs by severity. Threat modeling applied to new service deployments.	Implemented
CC3.3	COSO Principle 8: Assesses Fraud Risk	Insider threat detection via behavioral analytics: Splunk correlation searches detect anomalous login times, geographic anomalies, impossible travel scenarios, and unusual access patterns. Wazuh monitors account lifecycle events (creation, modification, privilege escalation) with alerts for high-risk activities. Authentik session management (30-minute idle timeout) limits exposure window from compromised sessions. All privileged actions require explicit MFA re-authentication. Least-privilege access prevents any single account from having broad blast radius.	Implemented
CC3.4	COSO Principle 9: Identifies and Analyzes Significant Change	Configuration drift detection via Ansible playbooks with automated baseline comparison. Wazuh File Integrity Monitoring (FIM) detects unauthorized changes to critical system files, configurations, and executables in real time. Git version control provides	Implemented

full change history for all IaC and configuration files with author attribution. SIEM alerts on policy-relevant changes: firewall rule modifications, user account changes, software installations outside approved channels. Snapshot-before-patch strategy captures pre-change state for rollback.

CC4: Monitoring of Controls

CC4.1	COSO Principle 16: Conducts Ongoing and/or Separate Evaluations	Continuous monitoring via dual SIEM (Splunk + Elastic) with 100+ active correlation rules, real-time detection of security events, and sub-5-minute MTTD for critical alerts. Wazuh Security Configuration Assessment (SCA) runs CIS Benchmark audits on all 31+ endpoints (25 on-premises + 6 cloud) continuously. Uptime Kuma monitors 50+ services with 60-second health check intervals. Prometheus node exporters provide 15-second metric collection from all hosts. Grafana dashboards track compliance posture, vulnerability trends, patch compliance, and authentication patterns in real time.	Implemented
CC4.2	COSO Principle 17: Evaluates and Communicates Deficiencies	Vulnerability findings routed to TheHive for structured tracking with remediation SLA enforcement (Critical less than 72h, High less than 7 days). Shuffle SOAR workflows automate escalation paths: high-severity Wazuh alerts auto-create TheHive cases with enrichment from Cortex (VirusTotal, AbuseIPDB, Shodan) and MISP. CIS Benchmark compliance deficiencies surfaced in Wazuh SCA reports with specific remediation guidance per failed check. Discord and email notifications ensure deficiencies reach the right channel within seconds of detection. Monthly compliance reviews update control baselines based on threat landscape changes.	Implemented

CC5: Control Activities

CC5.1	COSO Principle 10: Selects and Develops Control Activities	Defense-in-depth control architecture with overlapping controls at every layer: network perimeter (pfSense HA cluster, OPNsense, Palo Alto PA-VM with App-ID/Threat Prevention, FortiGate 30D), network detection (Suricata inline IPS, Snort passive IDS, CrowdSec behavioral, Zeek NSM, ntopng/nProbe flow analysis), application layer (SafeLine WAF, Traefik ForwardAuth, NGINX Ingress), identity (Authentik SSO, Active Directory, Step-CA PKI, MFA enforcement), and endpoint (Wazuh EDR, ClamAV, Microsoft Defender, FIM, rootkit detection). Controls selected based on MITRE ATT&CK technique coverage gaps and CIS Controls guidance.	Implemented
-------	--	--	-------------

CC5.2	COSO Principle 11: Selects and Develops General Controls over Technology	Technology controls enforced at infrastructure level: TLS 1.3 mandatory for all web services via Traefik (no protocol downgrade permitted), SSH password authentication globally disabled (key-based only), MFA enforced for 100% of administrative accounts via Authentik TOTP, default-deny firewall rules across all platforms (pfSense, OPNsense, Palo Alto, GCP VPC firewall, AWS Security Groups, Azure NSG), automated certificate lifecycle management via Step-CA (90-day rotation, ACME protocol), and DNSSEC validation enforced on all recursive resolvers. Weak cipher detection via automated Nessus compliance scans with remediation alerts.	Implemented
CC5.3	COSO Principle 12: Deploys Control Activities Through Policies and Procedures	Controls deployed as code: Ansible playbooks enforce CIS Benchmark baselines across 31+ hosts with drift detection alerting. Terraform defines network infrastructure (Security Groups, VPC firewall policies, NSG rules) as version-controlled IaC. Git branch protection and pull request requirements enforce peer review before policy changes. Wazuh SCA policies (CIS Amazon Linux, Debian 12/13, Ubuntu 22.04/24.04, Windows Server 2025, RHEL 10, CentOS 9) continuously validate control implementation. Policy exceptions require documented compensating controls and approval workflow.	Implemented

CC6: Logical and Physical Access Controls

CC6.1	Logical Access Security Software, Infrastructure, and Architectures	Logical access enforced through layered controls: Authentik SSO provides OAuth2/OIDC/SAML federation for 50+ services with centralized session management (30-minute idle timeout). Traefik ForwardAuth validates identity at the edge before proxying requests to any backend service. SSH access restricted to Ed25519 key-based authentication (passwords disabled globally via Ansible). Palo Alto PA-VM User-ID integration maps Active Directory group membership to firewall security policy, enforcing identity-aware network access independent of source IP. Step-CA PKI provides certificate-based device and service authentication. RBAC via Authentik groups with least-privilege scoping per application.	Implemented
CC6.2	Prior to Issuance of System Credentials, the Entity Registers and Authorizes New Users	User account provisioning requires explicit authorization: Authentik handles standard user provisioning with automated deprovisioning workflows; privileged account creation requires manual approval with documented justification. SSH key distribution centralized via Ansible with <code>authorized_keys</code> managed as IaC: no ad-hoc key	Implemented

		additions permitted. AWS IAM instance profiles assigned at provisioning time with minimum required permissions; no self-service IAM escalation. Windows domain accounts provisioned via Active Directory with OU-based Group Policy application. Account lifecycle tracked in Authentik with automated expiration for time-limited access (contractor accounts, 24-hour temporary elevation).	
CC6.3	The Entity Removes Access to Protected Information Assets When Appropriate	Access revocation enforced across all systems: Authentik account deactivation disables SSO access across all integrated services simultaneously. SSH key revocation deployed via Ansible playbook to all authorized_keys files within minutes. Tailscale node key expiry and revocation removes cloud node access. AWS IAM role disassociation, GCP service account removal, and Azure Entra ID account deactivation documented in decommissioning runbook. Wazuh monitors account lifecycle events (deletion, logout, privilege changes) with SIEM alerts for unexpected removals. Quarterly access reviews identify dormant accounts (45-day threshold) for deactivation.	Implemented
CC6.4	The Entity Restricts Physical Access to Facilities and Protected Information Assets	On-premises: server hardware located in dedicated locked area with residential physical security controls (alarm system, access restricted to authorized personnel). Proxmox management interface accessible only from homelab subnets: no internet-facing management ports. BIOS/UEFI passwords configured on physical hosts. Storage media (backup drives) stored in locked enclosure with AES-256 encryption at rest. Cloud nodes: physical security delegated to provider data centers (AWS, GCP, Azure) maintaining SOC 2 Type II / ISO 27001 physical access controls. No direct physical access to cloud hardware.	Implemented
CC6.5	The Entity Discontinues Logical Access to Protected Information Assets	Session termination enforced: Authentik session timeout (30-minute idle) automatically invalidates access tokens across all SSO-integrated services. SSH ClientAliveInterval=300 disconnects idle sessions. VPN sessions (Tailscale, PIA) require re-authentication per device policy. OAuth2 access tokens scoped with short expiration; refresh tokens rotated on use. Wazuh Active Response can disable accounts (account-disable action) in response to behavioral anomalies or brute-force detection. Cloud console sessions governed by provider session policies with MFA re-authentication requirements.	Implemented
CC6.6	The Entity Implements Logical Access	External threat controls: Safelane WAF (OWASP Core Rule Set) blocks SQL injection, XSS, command injection, path traversal, and RFI/LFI at the	Implemented

	Security Measures to Protect Against Threats from Sources Outside Its System Boundaries	application layer with 25%+ attack block rate. Suricata IPS with 40,000+ Emerging Threats signatures provides inline blocking on all perimeter interfaces. CrowdSec behavioral detection blocks brute-force, port scan, and exploit attempts via pfSense bouncer (less than 5 second enforcement). pfBlockerNG IP reputation blocking with 15+ curated feeds. GeoIP blocking for high-risk source countries. Cloudflare Tunnels expose no direct inbound ports; all external service access proxied through Cloudflare edge with DDoS protection. No inbound ports on any cloud management interface: all cloud access via Tailscale WireGuard.	
CC6.7	The Entity Restricts Transmission, Movement, and Removal of Information	Data transmission controls: TLS 1.3 mandatory for all web services (Traefik enforcement, modern cipher suites: AES-256-GCM, ChaCha20-Poly1305). syslog-ng TLS encrypts all log transmission to SIEM. VPN encryption via Tailscale WireGuard (ChaCha20-Poly1305) and PIA OpenVPN (AES-256). SSH AES-256-GCM for terminal access. Backup data encrypted with AES-256-GCM before transmission to Proxmox Backup Server. No unencrypted data paths exist on any managed system. Removable media restricted via Windows Group Policy (USB access denied by default). Cloud management traffic exclusively via Tailscale WireGuard: no plaintext management paths across any cloud provider.	Implemented
CC6.8	The Entity Implements Controls to Prevent or Detect and Act Upon the Introduction of Unauthorized or Malicious Software	Malware prevention and detection: Wazuh EDR provides FIM (real-time file hash comparison), rootkit detection, and process monitoring on 31+ endpoints (25 on-premises + 6 cloud). VirusTotal integration validates suspicious files via multi-engine analysis: automated quarantine triggered on positive detections (rule_id 87105). Yara rules detect malware signatures. ClamAV (Linux/FreeBSD/macOS) and Microsoft Defender (Windows) provide signature-based detection with automated signature updates. Suricata/Snort IDS signatures detect malware C2 communication and exploit payloads. Docker image verification via SHA-256 hashes and Docker Content Trust. Package signature validation (GPG keys) enforced for all software installations. Container images scanned before deployment.	Implemented
CC7: System Operations			
CC7.1	To Meet Its Objectives, the Entity Uses Detection and	Comprehensive monitoring stack: Dual SIEM (Splunk primary, Elastic secondary) ingests 100% of security events from 30+ data sources. Prometheus (15-second scrape interval) collects infrastructure	Implemented

	Monitoring Procedures	metrics from all hosts via node exporters. Uptime Kuma monitors 50+ services with 60-second health checks and TLS certificate expiration alerts. Checkmk provides deep infrastructure monitoring via agents on all managed hosts including cloud nodes. Pulse provides hypervisor-level visibility into Proxmox VE cluster health. Zeek NSM (3-worker AF_PACKET cluster) captures protocol metadata across Prod_LAN, Lab_LAN1, and Lab_LAN2. ntopng/nProbe aggregates NetFlow v9 from all Cisco routers and firewall platforms for flow-level visibility. Wazuh vulnerability assessment cross-references installed software against NVD daily.	
CC7.2	The Entity Monitors System Components and the Operation of Those Controls	Control effectiveness monitoring: CIS Benchmark compliance tracked via Wazuh SCA (92-98% pass rate across all enrolled hosts). Correlation rule effectiveness measured by alert-to-incident conversion rate in TheHive. WAF block rate (Safeline: 25%+ of inspected requests) monitored via dashboard. IDS signature hit rates tracked per interface (Suricata EVE JSON to SIEM). Certificate expiration monitored via Uptime Kuma (30/7/1-day warning thresholds). Patch compliance tracked in PatchMon with MTR trending. Authentik authentication failure rates tracked in Splunk for lockout threshold tuning. All monitoring data retained for 90 days (hot) and 1 year (cold) for trend analysis.	Implemented
CC7.3	The Entity Evaluates Security Events to Determine Whether They Could or Have Resulted in a Failure to Meet Its Objectives (Incidents)	Security event triage and classification: Splunk SPL correlation searches aggregate events across multiple sources and apply severity scoring. TheHive provides structured case management with MITRE ATT&CK technique tagging, severity matrix (Critical/High/Medium/Low), and incident classification taxonomy. Cortex multi-engine analysis (VirusTotal, AbuseIPDB, Shodan, MISP, Yara, Hybrid Analysis) enriches observables to determine if events constitute incidents. Shuffle SOAR automates initial triage: Wazuh alerts above severity threshold (level 4+) automatically create enriched TheHive cases within 45-60 seconds of detection. Alert suppression and deduplication configured to reduce analyst fatigue.	Implemented
CC7.4	The Entity Responds to Identified Security Incidents by Executing a Defined Incident	Incident response program: 15+ documented playbooks in TheHive covering phishing, malware, ransomware, lateral movement, brute force, vulnerability exploitation, and data exfiltration scenarios. Shuffle SOAR orchestrates automated containment: Wazuh Active Response executes firewall-drop, host-deny, and account-disable within	Implemented

	Response Program	sub-30-minute MTTR. Cortex responders provide automated evidence collection and IOC blocking. MSP integration enables rapid IOC correlation and sharing. Multi-channel notification (Discord, email, PagerDuty) ensures timely response. Cloud node containment via Wazuh Active Response over Tailscale, supplemented by provider-native controls (AWS Security Group modification, GCP Terraform firewall update, Azure NSG modification). All incident actions logged in TheHive with timestamped evidence chain.	
CC7.5	The Entity Identifies, Develops, and Implements Activities to Recover from Identified Security Incidents	Recovery capabilities: Proxmox snapshot-before-patch strategy enables rollback to known-good state within minutes. Proxmox Backup Server (bi-weekly automated backups, AES-256 encryption) with Synology NAS offsite redundancy provides sub-15-minute RTO for critical VMs. Infrastructure as Code (Terraform, Ansible) enables full lab rebuild from Git repository in less than 2 hours. Quarterly restore testing validates recovery procedures. Cloud node recovery via Ansible new_install_baseline_roles.yml, Tailscale re-enrollment, and Wazuh agent reinstallation (validated RTO less than 2 hours). Lessons learned from incidents drive playbook updates and Shuffle workflow optimization. Post-incident Wazuh SCA scan confirms security baseline compliance post-recovery.	Implemented
CC8: Change Management			
CC8.1	The Entity Authorizes, Designs, Develops or Acquires, Configures, Documents, Tests, and Approves Infrastructure, Data, Software, and Procedures	Formal change management process enforced through tooling: all infrastructure changes require Git commit with descriptive message (immutable audit trail). Terraform plan review required before cloud infrastructure changes applied: no ad-hoc console modifications. Ansible dry-run (--check mode) validates playbook impact before production execution. WSUS approval workflow requires explicit administrator sign-off before Windows patches deploy to production systems. Snapshot-before-patch captures pre-change state for rollback capability. Pre-deployment vulnerability scanning (OpenVAS, Nessus) validates new services before production. WSUS test deployments validate patch stability before production rollout. Container images verified via SHA-256 before deployment. Git branch protection and pull request reviews enforce peer approval for policy changes.	Implemented

CC9: Risk Mitigation

CC9.1	The Entity Identifies, Selects, and Develops Risk Mitigation Activities	Risk mitigation strategy: CVSS-based prioritization determines remediation sequence (Critical less than 72h, High less than 7 days, Medium less than 30 days). Virtual patching via SafeLine WAF rules provides immediate coverage for unpatched vulnerabilities. Network segmentation (VLAN isolation, firewall default-deny, Palo Alto zone architecture) contains blast radius of any compromise. Wazuh Active Response provides automated real-time mitigation (firewall-drop, account-disable) before manual response. Threat intelligence (MISP IOC correlation, CrowdSec community feeds) enables proactive blocking of known-bad infrastructure. HA firewall cluster (pfSense CARP, less than 5 second failover) and dual DNS (less than 5 second failover) mitigate availability risk.	Implemented
CC9.2	The Entity Assesses and Manages Risks Associated with Vendors and Business Partners	Third-party risk management: open-source software selected from vetted, actively maintained projects with strong community adoption. Docker images pulled from official repositories with SHA-256 signature verification. Package signature validation (GPG keys) enforced for all software installations via Ansible. MISP threat intelligence tracks vendor compromise campaigns and supply chain IOCs. PatchMon monitors all 5,000+ installed packages for CVEs including third-party dependencies. Cloud provider security posture assessed via provider-native tools: AWS GuardDuty and Security Hub, GCP Security Command Center, Azure Defender for Cloud. SBOM implementation (Trivy/Grype) planned Q2 2026 for comprehensive dependency visibility. No formal vendor contracts in scope (personal lab environment).	Partial

Coverage Summary

Status by Category

Category	Criteria	Implemented	Partial	Not Impl.	N/A	Assessment
CC1 Control Environment	5	3	2	0	0	Partial
CC2 Communication	3	3	0	0	0	Implemented
CC3 Risk Assessment	4	4	0	0	0	Implemented
CC4 Monitoring	2	2	0	0	0	Implemented
CC5 Control Activities	3	3	0	0	0	Implemented
CC6 Logical/Physical Access	8	8	0	0	0	Implemented

CC7 System Operations	5	5	0	0	0	Implemented
CC8 Change Management	1	1	0	0	0	Implemented
CC9 Risk Mitigation	2	1	1	0	0	Partial
TOTAL	33	30	3	0	0	Strong

Key Strengths

- CC6 (Logical Access) fully implemented: Authentik SSO, MFA enforcement, SSH key-based auth, Traefik ForwardAuth, Palo Alto User-ID AD group policy, session timeout, and per-service access control.
- CC7 (System Operations) fully implemented: dual SIEM with 100+ correlation rules, sub-5-minute MTTD, Shuffle SOAR with 15+ playbooks, sub-30-minute MTTR, Wazuh Active Response automated containment.
- CC5 (Control Activities) fully implemented: defense-in-depth architecture spanning 7 security layers, controls deployed as IaC with version-controlled policy enforcement.
- CC8 (Change Management) fully implemented: Git-enforced IaC workflow, Terraform plan review, Ansible dry-run validation, WSUS approval workflows, snapshot-before-patch rollback.
- Comprehensive cryptographic controls: TLS 1.3 mandatory, AES-256-GCM, Ed25519 SSH, Step-CA PKI with automated 90-day certificate rotation, DNSSEC validation.
- Cloud scope (AWS, Azure, GCP: 6 nodes): all Common Criteria controls extended to cloud nodes via Tailscale WireGuard, Wazuh EDR, Ansible, and provider-native security services (GuardDuty, SCC, Defender for Cloud).

Gaps and Observations

- CC1.1 / CC1.2 (Control Environment) rated Partial: formal policies, oversight structure, and board-level accountability mechanisms are constrained by the single-administrator personal lab context. In a service organization these would be addressed through executive governance, audit committees, and formal risk committees.
- CC9.2 (Vendor Risk) rated Partial: no formal vendor assessment program or contractual security requirements. SBOM tracking via Trivy/Grype planned to close the dependency visibility gap.
- SOC 2 context note: criteria requiring organizational governance structures (CC1.1-CC1.2), formal vendor agreements (CC9.2), and customer-facing privacy commitments are inherently limited by the personal lab scope. These are not technical gaps: the underlying security controls are implemented: but the organizational framework around them is not applicable.

Version History

Version	Date	Changes
1.0	April 2026	Initial release. Full Common Criteria (CC1-CC9) coverage. Hybrid cloud scope (AWS, Azure, GCP) included.